NEXUS / SGRSI

Informe final de implementacion de rubrica

Reestructuracion interna, arquitectura por capas, seguridad, persistencia, pruebas y preparacion de despliegue

Version evaluada	proyecto 3ra entrega
Repositorio	jeaan8/Implementacion-de-Rubrica (privado)
Desarrolladores	Jean Ortiz y Pablo Mecoll
Testers	Josefina Prieto y Thiago Rodriguez
Fecha de corte	19 de octubre de 2026

Resultado del bloque critico

La reestructuracion funcional y tecnica, la instalacion SQL aislada, las pruebas automatizadas y la regresion HTTP local finalizaron correctamente. El despliegue y smoke test desde la LAN institucional permanecen pendientes por requerir acceso fisico a esa red.

1. Resumen ejecutivo

La version activa de NEXUS conserva sus pantallas y contratos publicos, pero reemplaza la concentracion de reglas en endpoints por una estructura comprobable de aplicacion, dominio e infraestructura. Los endpoints actuan como adaptadores: autentican, validan el formato HTTP, delegan el caso de uso y traducen el resultado al contrato JSON comun.

El trabajo cubre incidencias, prestamos, servicios, inventario, usuarios, registro, cambios de rol, recuperacion de contrasena, seguridad de cuenta, Kanban, planillas TA, reportes, catalogos, configuracion, historial y fotografia de perfil.

Alcance confirmado

- 83 funciones documentadas mediante casos de prueba de caja blanca adaptados a la plantilla oficial.
- 19 adaptadores HTTP, 13 servicios de aplicacion, contratos de dominio y 13 repositorios PDO.
- Un unico instalador database.sql con 27 tablas y datos base reproducibles.
- Contrato JSON uniforme con status, message y data; codigos HTTP y permisos aplicados en servidor.
- Pruebas en memoria, integracion PDO, sintaxis PHP/JavaScript y regresion HTTP autenticada.

Exclusiones acordadas

- No se incorporan funciones de blacklist.
- No se incorporan planillas de clase; las planillas TA vigentes si forman parte del sistema.
- No se cambia el aspecto general de la interfaz salvo correcciones funcionales ya integradas.

2. Arquitectura implementada



Flujo de una operacion

El navegador envia una solicitud al adaptador HTTP. common.php establece sesion, autorizacion, CSRF, validacion de cuerpo y respuesta uniforme. El servicio de aplicacion ejecuta el caso de uso con objetos de dominio. El repositorio PDO encapsula SQL y transacciones. Ninguna regla central depende del HTML ni de variables globales dentro del servicio.

Elementos POO verificables

Elemento	Funcion
Servicios de aplicacion	Orquestan casos de uso y reglas transaccionales.
Interfaces de repositorio	Separan dominio de PDO y permiten dobles en memoria.
Objetos de valor	Validan cedula, rol y estados antes de persistir.
Excepciones de dominio	Transportan errores controlados sin exponer detalles SQL.
Adaptadores	Conectan HTTP, hash, TOTP, sesion, GD y MariaDB.

3. API, permisos y contrato

Grupo	Metodos	Regla principal
Incidencias	GET, POST, PUT, PATCH, DELETE	Alta Solicitante/Admin; gestion Tecnico/Admin
Prestamos	GET, POST, PUT, PATCH, DELETE	Alta Solicitante/Admin; gestion Tecnico/Admin
Servicios	GET, POST, PUT, PATCH, DELETE	Alta Solicitante/Admin; gestion Tecnico/Admin
Equipos y ubicaciones	GET, POST, PUT, PATCH, DELETE	Cambios Tecnico/Admin
Tareas y planillas TA	GET, POST, PUT, PATCH, DELETE	Tecnico/Admin
Usuarios y registro	GET, POST, PUT, PATCH, DELETE	Aprobacion y administracion Admin
Recuperacion y reportes	GET, POST, PUT, PATCH	Alta publica; tratamiento Tecnico/Admin
Catalogos y configuracion	GET, POST, PUT, PATCH, DELETE	Lectura autenticada; cambios Admin
Sesion y seguridad	GET, POST	Cuenta autenticada; 2FA obligatorio para Admin

Contrato de respuesta

Toda respuesta utiliza status, message y data. Los errores esperables se convierten en estados HTTP 400, 401, 403, 404, 405 o 429; las excepciones inesperadas se registran sin enviar mensajes internos de PDO al cliente.

Controles transversales

- Autorizacion nuevamente comprobada en cada solicitud, aunque el frontend oculte el boton.
- Token CSRF exigido para operaciones con estado y comprobacion de origen cuando existe cabecera Origin.
- Limitacion de peticiones de login, registro y API por identidad o direccion.
- Entrada JSON validada y campos normalizados antes de llegar al caso de uso.

4. Persistencia y modelo de datos

database.sql es el instalador canonico. Las migraciones anteriores se conservan dentro de database old solo como respaldo historico. La importacion limpia fue comprobada en MariaDB 10.4 sobre una base aislada.

Area	Tablas principales	Criterio aplicado
Identidad	usuario, solicitud_registro, solicitud_cambio_rol	Cuenta, aprobacion y rol separados
Soporte	incidencia, recuperacion_contrasena, reporte_error	Ticket y especializacion trazables
Servicios	servicio, solicita_servicio, servicio_disponible	Catalogo separado de solicitudes
Prestamos	prestamo, solicita_prestamo, categoria_prestamo	Relacion usuario-recurso y baja logica
Inventario	equipo, ubicacion, categoria_tecnologica	Ubicacion activa e historial
Trabajo	tareas, realiza_tarea, plantilla_tecnico_asistente	Tarea y asignacion consistentes
Auditoria	historial_*, seguridad_eventos, seguridad_intentos_login	Evidencia de cambios y accesos

Integridad transaccional

- Recuperacion: ticket, solicitud, cambio de hash y cierre se confirman o revierten juntos.
- Inventario: edicion, traslado o baja y registro historico comparten transaccion.
- Prestamo multiple: todos los equipos se crean o ninguno queda registrado parcialmente.
- Tarea: registro y asignacion se actualizan como una unidad.

5. Seguridad aplicada

Control	Implementacion	Estado
Contrasenas	Hash Argon2id/bcrypt y migracion de valores heredados al ingresar.	**Verificado**
Segundo factor	TOTP obligatorio para administrador, proteccion contra reutilizacion.	**Verificado**
Sesiones	Regeneracion de ID, version de sesion y cierre de sesiones anteriores.	**Verificado**
CSRF	Token y comprobacion de origen en operaciones mutables.	**Verificado**
Fuerza bruta	Contadores por cuenta/IP, ventana temporal y Retry-After.	**Verificado**
Archivos	MIME real, limite de tamano y recodificacion GD de imagenes.	**Verificado**
Errores	Respuesta generica al cliente y registro interno de excepciones.	**Verificado**
Transporte	HTTPS y cabeceras finales del servidor institucional.	**Pendiente LAN**

Principio de minimo privilegio

El rol Tecnico_Asistente atiende incidencias, prestamos, servicios, tareas y planillas, pero no recibe acciones de solicitud reservadas al Solicitante o Administrador ni administracion global de usuarios. Las decisiones de autorizacion viven en el servidor y no dependen de la visibilidad del menu.

6. Evidencia de pruebas

Nivel	Cobertura	Resultado
Aplicacion y dominio	100 comportamientos con repositorios en memoria	**Exitoso**
Persistencia	18 operaciones integradas con PDO real	**Exitoso**
Esquema	Importacion limpia de 27 tablas y 3 usuarios base	**Exitoso**
PHP	71 archivos de api y src	**Sin errores**
JavaScript	15 archivos	**Sin errores**
HTTP	17 adaptadores de consulta y 4 ciclos POST/DELETE	**Exitoso**
Autenticacion	Login administrativo, TOTP, sesion y CSRF	**Exitoso**
Visual local	Login, registro, recuperacion y 84 paginas de casos	**Exitoso**
LAN institucional	Tres roles, HTTPS y recorrido desde otra maquina	**Pendiente**

Casos de prueba

El documento de caja blanca contiene 83 casos en la plantilla oficial, uno por pagina, con descripcion simple, datos concretos, resultado esperado, resultado obtenido exitoso y responsables definidos. Las referencias tecnicas fueron alineadas con los endpoints reales de la version actual.

Criterio de honestidad

La evidencia automatizada permite afirmar que las reglas, persistencia y contratos locales funcionan. No se presenta como ejecutado ningun control que dependa de la red institucional: HTTPS, nombre de host, permisos del servidor y acceso desde otras estaciones deben verificarse in situ.

7. Trazabilidad del alcance

Familia funcional	Funciones representadas	Evidencia
Incidencias	Alta, baja, estados, toma, diagnostico, cierre, comentario y consultas	Servicios, repositorio, API y pruebas
Servicios	Solicitudes, catalogo disponible, estados, bajas y consultas	Servicios, catalogos y pruebas
Prestamos	Solicitud, recursos, categorias, estados, comentarios y consultas	Transacciones y pruebas
Inventario	Equipos, categorias, ubicaciones, traslado, historial y bajas	Inventario e historial
Trabajo	Tareas, dificultad, asignacion, Kanban En revision y planillas TA	Trabajo y planillas
Identidad	Registro, activacion, usuarios, roles, perfil y contrasena	Usuarios y solicitudes
Soporte publico	Reportes de error y recuperacion atendida por personal	Tickets y credencial temporal
Administracion	Catalogos, configuracion permitida, panel e historial	AdministracionService

Correspondencia documental

- Inventario API: rutas, metodos, acceso principal, capa POO y evidencia.
- Registro de decisiones: doce decisiones tecnicas con motivo y consecuencia.
- Casos de caja blanca: CT-01 a CT-83, sin blacklist ni planillas de clase.
- Guia de despliegue: requisitos, instalacion, smoke test y criterio de cierre.

8. Instalacion y despliegue

Procedimiento

1. Publicar exclusivamente proyecto 3ra entrega en el directorio definido por Apache.
2. Crear una base utf8mb4 e importar una sola vez database.sql.
3. Copiar config.example.php como config.php y completar host, puerto, base, usuario y clave.
4. Confirmar PDO MySQL, GD, mbstring y fileinfo; habilitar mod_rewrite y cabeceras.
5. Dar escritura al proceso web solo en uploads/perfiles y en el almacen de seguridad.
6. Configurar HTTPS y revisar CSP, anti-clickjacking y no-sniff.
7. Ejecutar el smoke test con Administrador, Tecnico_Asistente y Solicitante desde la LAN.
8. Comparar el commit desplegado con la etiqueta de cierre antes de aprobar la entrega.

Smoke test obligatorio en LAN

- Inicio/cierre de sesion, TOTP, CSRF valido e invalido para los tres roles.
- Alta y resolucion de incidencia, servicio y prestamo; comentario posterior cuando corresponda.
- Recuperacion, entrega de credencial temporal y primer ingreso exitoso.
- Alta, edicion integral, traslado y baja logica de equipo.
- Movimiento Kanban a En revision, edicion de dificultad y visibilidad de planillas TA.

9. Estado final y pendientes

Entregable o control	Estado	Observacion
Repositorio privado y respaldo	**Completo**	Backup inicial etiquetado y cambios en main.
Arquitectura por capas	**Completo**	Modulos funcionales migrados y probados.
Base de datos instalable	**Completo**	database.sql importado en limpio.
Casos de caja blanca	**Completo**	83 casos en la plantilla oficial.
Regresion local	**Completo**	Dominio, PDO, HTTP, sintaxis y visual.
Despliegue institucional	**Pendiente**	Requiere acceso a la LAN.
Etiqueta final de despliegue	**Pendiente**	Se crea luego del smoke test LAN.

Conclusion

El plan de prioridad critica queda implementado y verificado en el entorno local aislado. La arquitectura actual demuestra POO aplicada a casos de uso reales, separacion de responsabilidades, persistencia transaccional, autorizacion del lado servidor y evidencia repetible. El unico cierre no ejecutado es el despliegue institucional, correctamente mantenido como pendiente hasta disponer de acceso LAN.